Source: docs\technical\firestore-security.md | Export: 11 November 2026

> **Current shipping status (11 November 2026):** `DISTANCE_DELIVERY_ENABLED=false` by default. New checkout uses the existing saved flat shipping configuration, before coupons/points, with free shipping strictly above its saved threshold. Google Routes, dispatch coordinates, slabs and distance quotes are inactive. Historical order charges are unchanged. Distance-specific material below describes a retained, inactive implementation until a future explicitly approved re-enable. See current flat shipping reference.

Firestore data and security

For developers, security reviewers and operations owners. Baseline: inspected local source on 11 November 2026. Deployed rule/index equality, IAM, retention and backup configuration: **Pending confirmation**.

Data ownership

Project is `parinaya-silks`; database is `(default)`. Monetary amounts use integer paise; public/order snapshots may serialize amounts as decimal strings to preserve exact arithmetic. Timestamps differ by contract: Firestore timestamps, numeric milliseconds and date-only ETA values must not be interchanged.

Data path/group	Role and authority
`adminAccess/{uid}`	Server-provisioned enabled Admin permission; not customer-editable
`customerProfiles/{uid}`	Private customer identity/contact; narrow initial owner-create rule, subsequent supported changes through server
`customerDirectory/{uid}`	Derived Admin search/statistics/export projection; not an independent source of payment truth
`customerShopping/{uid}/bag`, `/wishlist`	Owned shopping references; server validates mutations
`customerShopping/{uid}/addresses`, `/preferences/delivery`	Private saved addresses and single default pointer
`customerShopping/{uid}/operations`	Order/address operation recovery receipts, as used by the relevant service
`categories`, `categorySlugs`, `categoryMedia`	Category visibility, permanent slug reservations and verified media
`products`, `productSlugs`, `productMedia`	Product identity, commercial fields, stock, permanent links and verified media
`orders/{id}`	Accepted commercial/address/loyalty/delivery/payment snapshots plus controlled lifecycle/history
`inventoryAudit`, `orderOperations`	Stock movement evidence and supported mutation receipts
`coupons/{code}`, `/customers/{uid}`	Coupon terms, global and customer usage, transactionally checked
`loyaltyAccounts/{uid}`, `/ledger/{entry}`	Private balance projection and stable order-linked ledger
`paymentAttempts`, `paymentProviderOrders`	Mode/key-bound attempt identity and provider-order mapping
`paymentEvents`, `paymentCheckoutLocks`	Accepted webhook evidence and unresolved-checkout protection
`paymentOperations/worker`, `paymentReconciliation`	Worker heartbeat and trusted reconciliation audit
`siteSettings/*`	Private content/settings source documents; served using safe public projections where appropriate
`campaigns`, `campaignSlugs`, media collections	Campaign configuration and identity/media reservations
`enquiries`, `enquiryReceipts`	Customer enquiry records and replay protection
`adminNotifications`, `adminNotificationReads`	Internal operator notifications and read markers
`deliveryQuotes`, `deliveryQuoteLimits`	Temporary route/fee quotations and per-UID calculation limiting

Rate-limit/media/operation supporting records are defined by their owning service. This table groups responsibilities; it is not permission to alter or delete every collection with a similar name.

Settings contracts

Existing settings include `storeContent`, `loginAppearance`, `loyalty`, `homepageBanners` and `storefrontAppearance`. Local delivery adds `dispatchLocation` v1, shipping v2 (`road-distance`) and `codAvailability` v1. Full settings remain private. `siteSettings/shippingRevision` is a signed-in read-only invalidation signal; its revision is not the complete shipping configuration.

Settings saves enforce expected revisions and operation identity/hash, preserving unrelated fields where the service uses merge semantics. Historical flat shipping remains readable for migration, but cannot authorize new orders in the local distance implementation. Settings changes do not rewrite accepted order snapshots.

Authorization and rules

`firestore.rules` requires both `request.auth.token.admin == true` and enabled `adminAccess/{uid}` for applicable direct Admin reads. Only a user may inspect their own permission record. Profiles/shopping/addresses are UID-owned; commerce writes generally use the trusted server. Private settings and other server-only records are denied directly. Absence of an explicit allow is denial; review additive wildcard allows before changing rules.

`server/catalog.ts` verifies tokens, project audience and both Admin checks before privileged modules. Transaction write paths recheck the enabled record. Payment customer operations verify order ownership; reconciliation requires authorized Admin access, webhooks require signatures and worker calls require their separate bearer secret.

The Admin SDK bypasses client rules. Do not infer that a default-deny client rule protects an unguarded server function. Never derive authorization from profile fields or client-supplied UID, totals or settings paths.

Indexes and query coupling

`firestore.indexes.json` defines groups for categories, products, orders, inventory audit, customer directory, enquiries and payment queues. Match complete query equality/order/range clauses to manifest definitions rather than adding guessed indexes.

Both `paymentEvents` and `paymentAttempts` define ascending `mode`, `keyId`, `nextCheckAt`. `server/payments/queue.ts` filters mode/key and due time, orders by `nextCheckAt`, then limits to 20. Publication/READY status is operational evidence and is **Pending confirmation** here. Existing report index audit is dated evidence, not a replacement for current metadata.

Delivery quote access uses direct document references. The existing private/default-deny rules cover these server-only collections; the delivery implementation did not publish a rule/index change.

Retention, backups and repairs

Delivery quotes expire in application logic after five minutes. `deliveryQuotes.deleteAfter` and `deliveryQuoteLimits.expiresAt` are Timestamp fields intended for TTL or an approved equivalent cleanup. Configuring TTL is separate from adding the fields. Retention/privacy compliance and actual cleanup activation are **Pending confirmation**.

Do not delete payment attempts/events, order history, inventory audit or loyalty ledger as routine queue cleanup. Retiring eligible terminal TEST schedules removes scheduling, not historical evidence. Repair/provisioning scripts are privileged operational tools; they require individual review and authorization, not execution during a build.

No automated backup/recovery deployment is established by this documentation. Confirm Firestore/Auth/media coverage, retention, restore ownership and recovery testing before describing backups as active.

Sources: `firestore.rules`, `firestore.indexes.json`, `server/catalog.ts`, `server/firebase.ts`, `server/credentials.ts`, `server/orders.ts`, `server/customerDirectory.ts`, `server/loyalty.ts`, `server/payments/`, `server/deliveryQuotes.ts`. Further detail: Admin access, loyalty, payment cutover, distance delivery.